Application des notes

Owner: YASSIR
Reviewer: AMINE
Contributors:
Date Generated: Mon Oct 26 2026

Executive Summary

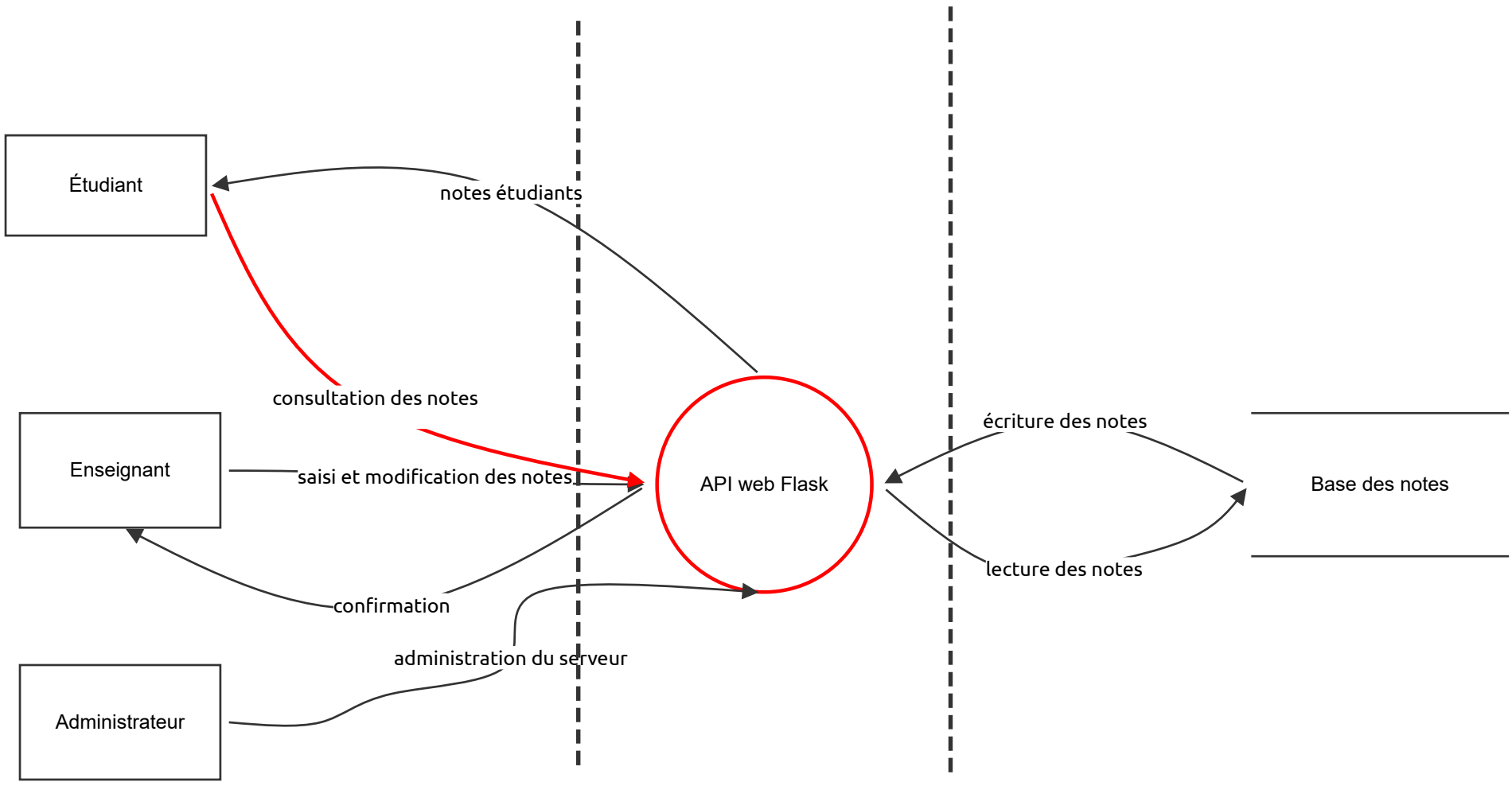
High level system description

L'école veut faire évoluer l'API : les étudiants consulteront leurs notes depuis leur téléphone, les enseignants saisiront et modifieront les notes, et un administrateur maintient le serveur. La base de données reste sur le serveur.

Summary

Total Threats	6
Total Mitigated	0
Total Open	6
Open / Critical Severity	1
Open / High Severity	5
Open / Medium Severity	0
Open / Low Severity	0

Flux de données



Flux de données

Étudiant (Actor)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Enseignant (Actor)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Administrateur (Actor)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

API web Flask (Process)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
5	Usurpation d'identité d'un utilisateur	Spoofing	High	Open		Une personne non autorisée se fait passer pour un étudiant ou un enseignant afin d'accéder à l'API.	Vérifier l'identité de l'utilisateur avec un jeton valide avant d'autoriser l'accès aux fonctions protégées.
6	Accès à des fonctions non autorisées	Elevation of privilege	Critical	Open		Un étudiant ou un enseignant accède à une fonction réservée à un rôle plus privilégié.	Vérifier côté serveur le rôle de l'utilisateur et ses permissions pour chaque opération sensible.
7	Injection SQL dans les requêtes de l'API	Tampering	High	Open		Une entrée malveillante peut modifier le comportement d'une requête SQL si les données reçues sont intégrées directement à la requête.	Utiliser des requêtes SQL paramétrées et valider les données reçues par l'API.

Base des notes (Store)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

administration du serveur (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

saisi et modification des notes (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

lecture des notes (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

écriture des notes (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

consultation des notes (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
2	Divulgation non autorisée des notes	Information disclosure	High	Open		Un étudiant peut consulter les notes d'autres étudiants sans autorisation.	Authentifier les utilisateurs et vérifier leurs droits avant de retourner les notes.
3	Falsification des données envoyées à l'API	Tampering	High	Open		Un utilisateur malveillant modifie les données envoyées à l'API pour tenter de modifier une note sans autorisation.	Valider les données reçues et vérifier les autorisations avant toute modification.
4	Indisponibilité de l'API par surcharge	Denial of service	High	Open		Un utilisateur envoie un grand nombre de requêtes et empêche les autres étudiants de consulter leurs notes.	Limiter le nombre de requêtes, surveiller la charge du serveur et gérer correctement les erreurs.

confirmation (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

notes étudiants (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations